École Supérieure des Communications de Tunis
SUP'COM

TupleTrace

CAHIER DES CHARGES

Plateforme sécurisée de partage de jeux de données traçables

Tatouage, stéganographie et empreinte numérique de données tabulaires

Module : Sécurité Applicative — Atelier PWA/SPA
Socle : Jakarta EE 11 — WildFly 42 — Java 25
Année universitaire : 2026–2027
Version : 2.0 — 11/11/2026

Réalisé par :
OMRANE Yosr
AMMAR Cheima
BEN AMOR Hayet

Encadré par :
Dr. Ing. Mohamed-Becha KAÂNICHE

Table des matières

1 Présentation du projet **3**
1.1 Cadre de l'atelier . . . 3
1.2 Problématique et fonctions essentielles . . . 3
1.3 Démonstration finale visée . . . 3

2 Contexte et problématique **4**
2.1 Contexte métier et acteur visé . . . 4
2.2 Le tuple : définition physique et contrat de données . . . 4
2.3 Identité stable et sérialisation canonique . . . 4
2.4 Les trois fraudes et les trois techniques . . . 4

3 Objectifs **5**
3.1 Objectifs métier . . . 5
3.2 Objectifs de sécurité . . . 5

4 Périmètre **5**
4.1 Inclus dans le projet . . . 5

5 Acteurs et rôles **6**

6 Principe et méthode de marquage **7**
6.1 Trois couches sur des lignes disjointes . . . 7
6.2 Méthode figée . . . 7
6.3 Contenu du sceau . . . 8
6.4 Calcul de capacité (estimations à valider au jalon J2) . . . 8
6.5 Gestion des clés . . . 9
6.6 Limites assumées . . . 9
6.7 Contrôles avant publication et états d'une distribution . . . 9

7 Scénario nominal **10**

8 Exigences non fonctionnelles (hors sécurité) **10**
8.1 Exigences non fonctionnelles . . . 10
8.2 Fiabilité du code métier : indicateurs SLI et objectifs SLO . . . 11

9 Contraintes techniques et architecture **11**
9.1 Socle technique . . . 11
9.2 Architecture cible . . . 12
9.3 Choix cryptographiques . . . 12

9.4 Ancrage WildFly 42 / Java 25 : sécurité et mémoire 12
9.5 Frontières de confiance : où le middleware intercepte, marque et chiffre 13

10 Démarche de sécurité **14**
10.1 Actifs et besoins C-I-D 14
10.2 Profils d'attaquants 14
10.3 Cas d'abus 15
10.4 Analyse STRIDE 16
10.5 Arbres d'attaque 16
10.6 Familles d'exigences et exemples 17
10.7 Menaces de transformation propres aux structures relationnelles 18
10.8 Menace interne : cas d'abus de l'attaquant légitime 18

11 Tests et évaluation expérimentale **20**
11.1 Banc d'essai 20
11.2 Simulateur de transformations 20
11.3 Indicateurs 20
11.4 Critères de recette 21
11.5 Traçabilité des campagnes complémentaires 21

12 Risques **21**
12.1 Risques projet 21
12.2 Conclusion et références 22

1. Présentation du projet

1.1 Cadre de l'atelier

Ce cahier des charges est réalisé dans le cadre de l'atelier du module Sécurité Applicative. Chaque équipe conçoit puis développe une application PWA/SPA dont la partie serveur repose sur Jakarta EE 11 (serveur WildFly 42, Java 25). L'énoncé impose trois contraintes :

— le métier doit faire la part belle aux services de dissimulation de l'information : stéganographie, watermarking, fingerprinting ;

— le périmètre métier est proportionnel à l'effectif de l'équipe, alors que les exigences de sécurité sont identiques pour toutes les équipes ;

— les aspects de sécurité suivent l'agenda du cours (chapitres 2 à 7) : l'application s'enrichit au fil des séances.

La progression est suivie sur un dépôt GitHub privé, partagé avec l'encadrant. Ce document et le recueil des besoins sont déposés en PDF dans le répertoire docs/.

Pour l'import PostgreSQL prévu dans le périmètre, l'utilisateur sélectionne une connexion et une table préalablement autorisées. Le serveur ouvre une connexion JDBC en lecture seule, inspecte le schéma, exige une clé primaire stable et lit les lignes par flux/curseur avec des limites de volume. Aucune requête SQL ni information de connexion fournie librement par le navigateur n'est exécutée ; les identifiants de connexion sont conservés côté serveur. Si ce flux ne peut pas être réalisé dans le MVP, l'import PostgreSQL sera explicitement reporté et le CSV restera le seul format livré.

1.2 Problématique et fonctions essentielles

Comment partager un jeu de données tabulaire avec plusieurs destinataires, tout en pouvant (1) établir à qui il appartient, (2) vérifier de façon autonome qu'il est authentique, et (3) identifier la copie dont provient un extrait retrouvé, sans dégrader significativement son utilité ?

— **Watermarking** : intégrer une marque commune, liée à la clé du propriétaire.

— **Stéganographie** : dissimuler dans le jeu lui-même un sceau signé et chiffré (identité, version, empreinte de l'original), vérifiable par un acteur autorisé sans consulter le registre des distributions, sous réserve de disposer du droit de déchiffrement et de la racine de confiance.

— **Fingerprinting** : produire une copie différente par destinataire, porteuse d'un code propre.

— **Investigation** : analyser un extrait suspect, rechercher ces trois marques et produire un rapport argumenté, avec un niveau de confiance et ses réserves.

1.3 Démonstration finale visée

Un propriétaire importe un CSV, choisit les colonnes marquables et leurs tolérances, protège le jeu. Un gestionnaire prépare des copies pour plusieurs destinataires ; le propriétaire valide ; chaque destinataire télécharge la sienne. Un enquêteur soumet ensuite un extrait modifié : la plateforme retrouve la marque du propriétaire, le sceau si les données sont suffisantes, puis l'empreinte de la copie, et génère un rapport signé.

Limite assumée : retrouver la copie d'un destinataire ne prouve pas que cette personne a elle-même divulgué les données. Le rapport formule un indice technique, jamais une accusation.

2. Contexte et problématique

2.1 Contexte métier et acteur visé

TupleTrace s'adresse aux détenteurs de jeux de données de recherche partagés avec de nombreux destinataires (institutions, laboratoires, partenaires), qui doivent pouvoir prouver leur propriété, l'authenticité d'un jeu et l'origine d'une fuite. Dans le périmètre de TupleTrace, nous étudions surtout la fuite après un accès légitime : un partenaire autorisé peut partager sans permission une copie qu'il a reçue. Le fingerprinting vise à identifier la copie distribuée à l'origine de cet extrait, sans attribuer automatiquement la responsabilité de la fuite. Seules les colonnes numériques pour lesquelles une tolérance est définie peuvent être marquées (voir § 6.2) ; les identifiants, dates, codes et catégories restent inchangés.

2.2 Le tuple : définition physique et contrat de données

Le cœur du sujet est la ligne de données, ou **tuple**, et non le fichier qui la transporte. TupleTrace marque, distribue et retrouve des tuples : l'enjeu de sécurité porte donc sur la structure relationnelle (identité d'un tuple, ordre des attributs, collisions de clés), et pas seulement sur la confidentialité d'un fichier plat.

Définition. Un tuple est un enregistrement (une ligne) d'une relation, composé d'attributs typés et identifié par une clé stable. Il ne doit pas être confondu avec une ligne de texte brute d'un CSV : la position physique d'une ligne ou d'une colonne n'est jamais une identité. Pour chaque jeu importé, TupleTrace construit un schéma logique versionné et une identité de tuple stable.

Exemple concret. Le tuple (record_id=1001, sensor_id='S17', temperature=21.37, humidity=57.82) appartient à une table dont record_id est la clé stable. Avec un pas $\delta = 0{,}01$ et une tolérance de colonne $\geq 0{,}01$, l'insertion d'un bit laisse temperature à 21.37 (bit 1) ou la porte à 21.38 (bit 0, selon la règle de départage définie par la version de l'algorithme). L'écart est de 0,01. En revanche, record_id et sensor_id ne sont jamais modifiés.

2.3 Identité stable et sérialisation canonique

Chaque jeu possède un identifiant `id_jeu` et une version de schéma. Chaque tuple est identifié par une clé primaire déclarée (pk), unique et non nulle. L'identité utilisée par les fonctions cryptographiques est construite à partir de `id_jeu`, de la version du schéma et de la pk ; elle ne dépend ni du numéro de ligne ni de la position des colonnes.

La sérialisation est versionnée et non ambiguë : chaque champ est encodé avec son type, sa longueur et sa valeur canonique. Les valeurs nulles, les chaînes, les nombres et les dates ont des représentations distinctes. Les séparateurs seuls ne sont jamais utilisés pour construire l'identité (par exemple, les couples `(12,34)` et `(1,234)` doivent produire des encodages différents). L'identité sémantique d'une cellule est le quadruplet `(id_jeu, version_schéma, pk, attribute_id)`. Un renommage d'attribut n'est accepté que si un mapping versionné explicite est fourni ; sinon l'import est refusé ou l'investigation reste indéterminée.

2.4 Les trois fraudes et les trois techniques

TupleTrace répond à un problème unique : savoir à qui appartient un jeu de données, s'il est authentique et d'où provient une fuite. Ce problème recouvre trois situations distinctes ; chaque technique de l'énoncé en traite une.

Situation	Exemple	Technique	Ce qu'elle prouve
Réutilisation non autorisée	Extrait republié sans mention de provenance	Watermarking : marque commune liée à la clé du propriétaire	À qui appartiennent les données
Jeu falsifié ou usurpé	Valeurs retouchées, jeu présenté comme officiel	Stéganographie : sceau signé caché dans les lignes	Ce qui a été publié, par qui, dans quelle version
Fuite par un partenaire	Copie diffusée publiquement	Fingerprinting : code unique par copie	À qui la copie a été remise

3. Objectifs

3.1 Objectifs métier

Code	Objectif	Indicateur de réussite
OM-1	Protéger un jeu de données sans en détruire l'utilité	Cible expérimentale : protection de 100 000 lignes en moins de 60 s sur le serveur de référence ; erreur par valeur $\leq$ tolérance de la colonne. Mesure et validation au jalon J2
OM-2	Distribuer des copies individualisées sous contrôle	$\leq$ 30 destinataires par jeu ; double validation ; registre signé
OM-3	Reconnaître l'origine d'un extrait modifié	Marque de propriété détectée ($p < 10^{-6}$) après suppression de 50 % des lignes ; copie attribuée dans $\geq$ 95 % des cas à partir de 20 % des lignes
OM-4	Ne jamais sur-conclure	Aucune fausse attribution sur 1 000 extraits non marqués ; verdict « Indéterminé » quand les données sont insuffisantes
OM-5	Offrir une application installable et simple	PWA installable ; parcours importer $\rightarrow$ protéger $\rightarrow$ distribuer $\rightarrow$ enquêter ; verdict d'investigation en 3 écrans maximum

3.2 Objectifs de sécurité

Principe imposé	Traduction dans TupleTrace
Shift-Left	$\geq$ 50 exigences de sécurité (SR) rédigées avant la première ligne de code métier ; chaque fonctionnalité a ses cas d'abus avant d'être développée
Perspective de l'attaquant	18 cas d'abus, 6 profils d'attaquants, 2 arbres d'attaque, analyse STRIDE
Triptyque C-I-D	Besoins C-I-D cotés pour chacun des 9 actifs ; la confidentialité des originaux et des clés et l'intégrité du registre sont les propriétés dominantes

4. Périmètre

4.1 Inclus dans le projet

Module	Contenu	Besoins
Socle	Comptes, activation par invitation, MFA, données personnelles	BF-CPT-01 à 05
Jeux de données	Import CSV ou connexion JDBC en lecture seule à une table PostgreSQL autorisée ; profilage, colonnes et tolérances, versions	BF-JDD-01 à 05
Watermarking	Marque commune, rapport de qualité, refus si tolérance impossible	BF-WM-01 à 03
Stéganographie	Sceau caché signé, affichage des métadonnées extraites, vérification autoportée	BF-STG-01 à 03
Fingerprinting	Destinataires, double validation, copies, téléchargement contrôlé, révocation, registre signé	BF-FP-01 à 06
Investigation	Extrait suspect, tests statistiques, verdict à 4 statuts, rapport signé, simulateur	BF-INV-01 à 07
Administration / PWA	Comptes, quotas, audit, clés ; application installable	BF-ADM-01 à 04, BF-PWA-01, 02

5. Acteurs et rôles

Acteur	Description	Ce qu'il peut faire
Propriétaire (MFA obligatoire)	Responsable des données d'une organisation	Importer, protéger, valider les distributions, révoquer, consulter les enquêtes de son organisation
Gestionnaire de distribution	Personnel de l'organisation propriétaire	Gérer les destinataires, préparer les distributions (sans pouvoir les valider)
Destinataire	Partenaire, client ou chercheur invité	Télécharger uniquement la copie qui lui est attribuée
Enquêteur	Personne habilitée de l'organisation propriétaire	Soumettre un extrait suspect, consulter ses résultats, exporter un rapport
Administrateur technique (MFA obligatoire)	Exploitant de la plateforme	Gérer comptes, organisations et quotas, sans accès aux jeux de données ni aux clés
Auditeur (MFA obligatoire)	Responsable sécurité	Lecture seule des journaux, alertes et état de la chaîne d'intégrité

La matrice ci-dessous fixe les droits par défaut. Toute case vide est un refus (refus par défaut, SR-AUZ-01).

Fonction	Propr.	Gest.	Dest.	Enq.	Admin	Audit.
Importer, profiler un jeu	✓ (son org.)					
Choisir colonnes et tolérances, protéger	✓ (MFA)					
Préparer une distribution		✓ (son org.)				
Valider et générer les copies	✓ (≠ préparateur)					
Révoquer un accès	✓	✓				
Télécharger une copie			✓ (la sienne)			
Soumettre un extrait, lancer une investigation				✓		
Consulter un rapport d'investigation	✓ (son org.)			✓ (les siens)		
Gérer comptes, organisations, quotas					✓ (MFA)	

Fonction	Propr.	Gest.	Dest.	Enq.	Admin	Audit.
Consulter les métadonnées et le profil d'un jeu	✓ (son org.)				non	
Lire une clé cryptographique secrète via l'API	non	non	non	non	non	non
Consulter journaux et alertes	son historique					✓ lecture (MFA)
Modifier ou supprimer un journal	non	non	non	non	non	non

Les originaux non marqués et les clés secrètes ne sont pas exposés par l'API. Le propriétaire consulte les métadonnées, le profil et les rapports de ses jeux ; les traitements autorisés utilisent les clés uniquement côté serveur (SR-CON-02, SR-CON-03).

6. Principe et méthode de marquage

6.1 Trois couches sur des lignes disjointes

TupleTrace s'inspire du tatouage des bases relationnelles d'Agrawal et Kiernan. Une fraction des lignes est sélectionnée par une fonction cryptographique à clé, puis répartie en trois ensembles disjoints : filigrane, sceau, empreinte.

6.2 Méthode figée

Notations. Dans les formules ci-dessous, $\|$ désigne la concaténation par champs de longueur explicite et versionnée (§ 2.3), et pk désigne l'identité sérialisée du tuple, ser(id_jeu, version_schéma, pk). La sélection et les bits attendus ne dépendent donc jamais de la position d'une ligne ou d'une colonne dans le fichier.

Étape	Règle
Identification des lignes	Par clé stable déclarée (pk), unique et non nulle (§ 2.3). Aucune dépendance à l'ordre des lignes. Import sans clé stable refusé pour le MVP
Sélection des lignes	Ligne marquable si HMAC-SHA-256(K, pk) mod $\gamma = 0$; $\gamma = 5$ par défaut ($\approx$ 20 % des lignes), réglable de 2 à 20
Répartition en couches	HMAC(K, pk$\|$layer) mod 3 : 0 = filigrane, 1 = sceau, 2 = empreinte
Choix de la colonne	HMAC(K, pk$\|$col) mod ν, parmi les ν colonnes éligibles, ordonnées par attribute_id (ordre canonique, indépendant de leur position dans le fichier)
Insertion	Quantification à pas δ (QIM) : pour insérer le bit b, la valeur x est remplacée par le point $\delta \cdot (2k + b)$ le plus proche ; l'erreur est $\leq \delta$; pour chaque colonne, le pas choisi doit vérifier $\delta_c \leq T_c$, où T_c est sa tolérance configurée. Colonnes entières : δ entier ≥ 1. Refus de l'opération si δ_c est incompatible avec la résolution ou la tolérance de la colonne
Bit du filigrane	b = bit de HMAC(Kwm, pk) : motif pseudo-aléatoire, identique sur toutes les copies
Bit du sceau	Bit d'indice HMAC(Kstg, pk) mod n du sceau codé (Reed-Solomon, taux 1/2), répété sur plusieurs lignes ; lecture par vote majoritaire
Bit de l'empreinte	Position j = HMAC(K, pk) mod 64 ; valeur = bit j du code de la copie ; code = 64 premiers bits de HMAC(Ki, fp), avec Ki = HKDF-SHA-256(Kmaitre, id_copie)
Détection du filigrane	Relecture des bits (parité de round(x/δ)) aux lignes re-sélectionnées par la clé ; test binomial unilatéral (H0 : p = 0,5), seuil $p < 10^{-6}$

Étape	Règle
Identification de l'empreinte	Corrélation du code extrait (vote par bit) avec les N codes du registre ; distance de Hamming minimale ; test binomial au seuil α/N (Bonferroni, $\alpha = 10^{-3}$)
Verdict	Marque reconnue · Copie identifiée · Indéterminé · Aucune marque détectée (cf. § 11)

6.3 Contenu du sceau

Le contenu signé comprend : version du format (1 octet), id_jeu (16 octets), id_propriétaire (8 octets), hash SHA-256 tronqué de l'original (16 octets), date (4 octets) et identifiant de clé (8 octets), soit 53 octets. La signature Ed25519 (64 octets) porte sur l'ensemble exact de ces champs, dans leur encodage canonique versionné. Le contenu signé représente donc 117 octets.

Le sceau chiffré par AES-256-GCM contient le nonce de 96 bits, le texte chiffré et l'étiquette d'authentification de 128 bits. Le nonce est généré aléatoirement par un générateur cryptographiquement sûr pour chaque opération de chiffrement ; il n'est jamais dérivé de `id_jeu`. Il doit être unique pour une même clé AES. Le nonce et l'étiquette sont stockés avec le texte chiffré. Pour éviter toute réutilisation, la conception prévoit une clé de chiffrement dédiée/versionnée par contexte et un contrôle de non-réutilisation des nonces.

Pour une vérification autonome par un vérificateur autorisé, le sceau transporte également la clé publique Ed25519 (32 octets) et son identifiant ; cette clé doit être reliée à l'identité du propriétaire par un certificat ou manifeste signé par une autorité de confiance connue du vérificateur. Comme le sceau est chiffré, le vérificateur doit aussi disposer d'un droit de déchiffrement et de la clé correspondante. La vérification ne dépend pas du registre des distributions, mais elle dépend nécessairement de cette capacité de déchiffrement et de cette racine de confiance. Une vérification publique sans secret de déchiffrement exigerait un sceau signé mais non chiffré, variante qui n'est pas retenue dans le MVP. La taille binaire avant code correcteur est ainsi d'environ 177 octets (117 octets de contenu signé + 32 octets de clé publique + 12 octets de nonce + 16 octets d'étiquette). Avec un code correcteur de taux 1/2, la capacité à réserver est d'environ 2 832 bits, arrondie à 2 900 bits. Cette estimation reste à valider au jalon J2.

6.4 Calcul de capacité (estimations à valider au jalon J2)

Jeu de 100 000 lignes, $\gamma = 5$	Valeur
Lignes marquées	≈ 20 000
Par couche	≈ 6 667
Redondance du sceau	Environ 2 832 bits codés pour l'hypothèse décrite (§ 6.3), arrondis à 2 900 ; couverture effective des positions et seuil de récupération à mesurer
Redondance de l'empreinte	≈ 104 lignes par bit du code ; ≈ 21 sur un extrait de 20 %
Filigrane sur extrait de 1 000 lignes	≈ 67 lignes testées, p ≈ 2^{-67} en cas de concordance totale
Taille minimale pour activer le sceau	Pas de seuil fixe validé : activation uniquement si le test de capacité et l'essai de décodage réussissent pour la taille, le schéma et le taux d'effacement annoncés

Vérification obligatoire de capacité. Si un tuple fournit au maximum un bit dans la couche sceau, le nombre moyen de positions disponibles est approximativement

$$N_B \simeq \frac{N}{3\gamma}, \qquad N_{B,\,70\%} \simeq 0{,}70\,\frac{N}{3\gamma}.$$

Pour $N = 50\,000$ et $\gamma = 5$, cela donne environ 3 333 positions initiales puis 2 333 après conservation de 70 % des lignes, contre un budget d'environ 2 832 bits codés. La simple annonce d'un seuil

minimal à 50 000 lignes n'est donc pas justifiée. Pour $N = 100\,000$, il reste environ 4 667 positions avant prise en compte de la répétition de certains indices HMAC.

Le marquage n'est autorisé que si une campagne reproductible démontre la récupération du sceau pour la taille, le nombre de colonnes éligibles et la proportion d'effacement considérés. La distribution des indices, les duplications, les erreurs de bits et la capacité de correction du code Reed–Solomon sont mesurées ; un test de capacité fondé uniquement sur le nombre brut de lignes ne suffit pas. Sinon, le sceau est désactivé avec une explication vérifiable, sans compromettre les autres couches.

6.5 Gestion des clés

Les clés de marquage et de signature sont générées à l'inscription d'une organisation et conservées dans le credential store Elytron ; les sous-clés sont dérivées par HKDF. Le mot de passe ou secret qui protège le credential store n'est pas enregistré dans le dépôt, dans la base métier ni à côté du fichier du store : il est injecté au démarrage depuis un mécanisme de secrets de déploiement ou un secret système protégé, avec des droits d'accès minimaux. Le fichier du store et ses sauvegardes sont protégés par les permissions du système et stockés séparément du secret maître. La procédure de restauration et de rotation est documentée et testée. Les anciennes versions de clés restent disponibles pour la détection, selon une politique de rétention (BF-ADM-04).

6.6 Limites assumées

— Le marquage par quantification résiste à un bruit d'amplitude $< \delta/2$; un arrondi plus grossier que δ ou un bruit plus fort détruit la marque : le détecteur répond alors « Indéterminé » ou « Aucune marque détectée », jamais une attribution forcée.

— Plusieurs destinataires comparant leurs copies peuvent localiser les lignes d'empreinte (collusion, hors périmètre) ; la couche filigrane, identique sur toutes les copies, n'est pas affectée.

— Le sceau authentifie l'identité et la version du jeu ; l'intégrité de chaque valeur d'un fichier exact est vérifiée par comparaison du SHA-256 avec le registre.

— Le prototype ne reconnaît pas un tuple dont la clé stable a été supprimée ou dont l'identité est ambiguë (doublons, renommage non reconnu) : le verdict est « Indéterminé » (§ 2.3).

6.7 Contrôles avant publication et états d'une distribution

Aucune copie n'est téléchargeable tant que les contrôles suivants ne sont pas tous réussis. Le marquage est appliqué dans une zone temporaire privée, jamais directement dans l'espace de stockage des copies publiées.

— Valider la présence et l'unicité de toutes les clés de tuple (pk non nulle, sans doublon) et l'absence d'en-tête dupliqué.

— Construire la table de correspondance des attributs sémantiques (attribute_id) à partir du schéma versionné.

— Calculer les cellules admissibles et exclure les colonnes interdites ou de tolérance 0.

— Appliquer le marquage dans la zone privée temporaire, par lots (§ 9.4).

— Recalculer l'erreur absolue maximale et moyenne, les extrêmes, ainsi que les moyennes et variances par colonne (rapport de qualité, BF-WM-02).

— Vérifier la reproductibilité de la sélection après permutation contrôlée des lignes et des colonnes.

— N'activer le téléchargement qu'après validation du fichier, signature du registre et validation de la transaction de distribution.

États d'une distribution : PENDING, VALIDATED, FAILED, REVOKED. Une copie en cours de génération n'est pas visible. Un calcul interrompu ou une transaction invalide produit l'état FAILED, sans fichier final accessible. La révocation bloque les nouveaux téléchargements (BF-FP-05) sans prétendre supprimer les copies déjà obtenues hors de la plateforme.

7. Scénario nominal

— La propriétaire d'une organisation importe un CSV de mesures, consulte le profil des colonnes et retient trois colonnes numériques avec leurs tolérances (BF-JDD-01 à 04).

— Elle protège le jeu, connectée avec son second facteur : la plateforme insère filigrane et sceau, puis produit le rapport de qualité (BF-WM-01 à 03, BF-STG-01).

— Le gestionnaire prépare une distribution pour trois partenaires (BF-FP-02).

— La propriétaire valide ($\neq$ préparateur, SR-AUZ-03) ; trois copies à empreinte distincte sont générées et enregistrées dans le registre signé (BF-FP-03, 06).

— Chaque partenaire active son compte et télécharge uniquement sa copie, via un lien temporaire (BF-FP-04).

— Un extrait de 20 % des lignes, légèrement bruité, est retrouvé en ligne. L'enquêteur le soumet (BF-INV-01).

— La plateforme reconnaît le filigrane ($p < 10^{-6}$), identifie la copie du partenaire n° 2 (seuil α/N) et produit un rapport signé rappelant que cela ne prouve pas la responsabilité du partenaire (BF-INV-02 à 05).

— Si l'extrait est trop petit ou trop dégradé, le verdict est « Indéterminé » et le rapport en explique la raison.

Scénarios de refus liés à la structure des tuples

— **Ambiguïté d'attribut ou de clé.** Un fichier contient deux colonnes temperature ou une pk dupliquée : aucun marquage n'est commencé. L'application renvoie une erreur au format RFC 9457, liée à un identifiant de traitement auditable, sans divulguer les valeurs des tuples à l'écran ni dans les journaux.

— **Insuffisance statistique.** L'extrait contient trop peu de cellules utilisables, les marques ont été détruites par une transformation ou plusieurs copies restent candidates : le verdict est « Indéterminé » et le rapport donne la raison concrète de l'abstention.

8. Exigences non fonctionnelles (hors sécurité)

8.1 Exigences non fonctionnelles

Les valeurs du tableau sont des objectifs expérimentaux initiaux, et non des performances déjà démontrées. Elles seront mesurées au jalon J2 sur une machine de référence décrite (CPU, RAM, JVM, système), puis confirmées ou révisées avec justification dans le rapport SRE.

Code	Domaine	Exigence
ENF-01	Performance	Protection de 10 000 lignes en moins de 5 s ; de 100 000 lignes en moins de 60 s (serveur 4 vCPU)
ENF-02	Performance	Investigation d'un extrait de 10 000 lignes en moins de 30 s contre 30 destinataires
ENF-03	Performance	Écrans de navigation en moins de 500 ms au 95e centile ; traitements longs asynchrones
ENF-04	Utilité	Erreur par valeur $\leq$ tolérance de la colonne ; erreur relative moyenne $\leq$ 0,1 % ; écart sur moyenne et variance $\leq$ 0,5 %
ENF-05	Robustesse	Filigrane détecté ($p < 10^{-6}$) après suppression de 50 % des lignes, arrondi à une précision $\geq \delta$, bruit uniforme d'amplitude $\leq \delta/4$, réordonnancement quelconque
ENF-06	Fiabilité	Seuil binomial $p < 10^{-6}$ par test (hypothèses à vérifier) ; cible expérimentale : 0 fausse attribution sur 1 000 témoins non marqués, sans prétendre démontrer un taux réel de 10^{-6}
ENF-07	Attribution	$\geq$ 95 % de copies correctement identifiées sur un extrait $\geq$ 20 % des lignes (jeu $\geq$ 100 000 lignes, $\leq$ 30 destinataires)
ENF-08	Reproductibilité	Même jeu, même configuration, même graine : résultats identiques
ENF-09	Compatibilité	Deux dernières versions de Chrome, Firefox, Edge, Safari ; de 360 px à 1920 px ; connexions lentes (3G)
ENF-10	Ergonomie	Interface en français ; contraste WCAG 2.1 AA ; verdict compréhensible par un non-spécialiste (couleur + texte + explication)
ENF-11	Maintenabilité	Couverture de tests $\geq$ 70 % sur les services métier et 90 % sur le moteur ; API documentée en OpenAPI 3.1

8.2 Fiabilité du code métier : indicateurs SLI et objectifs SLO

Le suivi de fiabilité applicative porte sur la fiabilité et la résilience du code métier de dissimulation (marquage, extraction et attribution), et non sur la haute disponibilité de l'infrastructure, qui est hors périmètre. Les indicateurs suivis comprennent notamment la validation sûre des imports, la conformité de la distorsion, l'atomicité des distributions, le taux d'erreur d'extraction (BER), la récupération du sceau, la précision d'attribution, les faux positifs, le taux d'indétermination, les latences p95 et les erreurs de heap.

Les définitions précises des SLI, leurs SLO initiaux, les méthodes de collecte, les seuils d'alerte, les fenêtres de mesure et les preuves attendues sont regroupés dans le document SRE afin d'éviter les doublons avec le présent cahier des charges. Toutes les valeurs restent des cibles à mesurer au jalon J2 ; aucune cible n'est présentée comme un résultat acquis. Un banc de 1 000 témoins sans erreur ne suffit pas à démontrer un taux de faux positifs de 10^{-6} : la limite statistique observée et les hypothèses du modèle binomial seront rapportées séparément.

9. Contraintes techniques et architecture

9.1 Socle technique

Couche	Technologie	Usage dans TupleTrace
Langage / JVM	Java 25 (LTS)	Back-end, moteur de marquage, EdDSA (Ed25519) natif
Serveur d'application	WildFly 42	Déploiement du WAR, Elytron (sécurité, credential store), Undertow (HTTP/TLS)
Plateforme	Jakarta EE 11	REST 4.0 (API), CDI 4.1 (services), Persistence 3.2 + Data 1.0 (requêtes paramétrées), Validation 3.1, Security 4.0, Concurrency 3.1, JSON Binding 3.0

Couche	Technologie	Usage dans TupleTrace
Cryptographie	JCA + Bouncy Castle	HMAC-SHA-256, HKDF, AES-256-GCM, Argon2id, Ed25519, ES256 (JWT)
Données tabulaires	Parsing CSV (bibliothèque auditée) et JDBC en lecture seule	Import en flux, profilage, export sécurisé
Base de données	PostgreSQL 17	Métadonnées, registre, audit ; clés hors base
Client	React 19 + TypeScript, Vite, vite-plugin-pwa	Espaces propriétaire, destinataire, enquêteur ; Service Worker
Intégration continue	GitHub Actions	Build, tests, SAST, SCA, recherche de secrets

9.2 Architecture cible

L'architecture est en trois couches. Le moteur TupleTrace concentre le marquage ; il s'exécute dans une file de traitement bornée. Les clés ne quittent jamais le serveur.

Schéma de circulation des données (lecture textuelle)

Navigateur (PWA / SPA) — zone non fiable : Service Worker (cache statique uniquement) · Interface React + TypeScript (propriétaire, destinataire, enquêteur)

▼ F1 — HTTPS TLS 1.3 · JWT en mémoire ▼

WildFly 42 — Jakarta EE 11 / Java 25 — zone de confiance serveur

Jakarta REST /api/** ▷ Jakarta Security + Elytron : JWT ES256, RBAC, MFA

Services CDI : Import · Distribution · Investigation

▼ F2 — tuples canonisés et validés + SecurityContext ▼

Moteur TupleTrace : filigrane · sceau · empreinte ▷ Jakarta Concurrency : file bornée, timeout 60 s

Signatures Ed25519 + audit chaîné ▷ Credential store Elytron (clé maître) **◀ F4**

▼ F3 — copie chiffrée AES-256-GCM après validation ▼

PostgreSQL 17 : registre, audit ▷ Stockage fichiers chiffré AES-GCM ▷ Journal (ajout seul)

Figure 1 – Architecture logique de TupleTrace et frontières de confiance F1 à F4 (§ 9.5)

9.3 Choix cryptographiques

Besoin	Mécanisme
Mots de passe	Argon2id
Chiffrement des fichiers et du sceau	AES-256-GCM
Signatures (sceau, registre, rapports)	Ed25519 ; clé publique identifiée par key_id et liée au propriétaire par un certificat/manifeste signé et vérifié jusqu'à une racine de confiance
Jetons d'accès	JWT ES256, durée courte, refresh avec rotation
Sélection des lignes, bits attendus	HMAC-SHA-256 à clé, sur une identité de tuple sérialisée à champs de longueur explicite (§ 2.3)
Dérivation des sous-clés de copie	HKDF-SHA-256
Chaînage du journal	Hash SHA-256 de l'entrée précédente, signé périodiquement

9.4 Ancrage WildFly 42 / Java 25 : sécurité et mémoire

Les exigences de sécurité sont contextualisées face aux contraintes du middleware : API de Jakarta Security 4.0 et Elytron pour l'identité, et gestion de la heap Java 25 pour les traitements de gros

volumes. Les valeurs chiffrées sont des **valeurs de départ**, à calibrer par profilage au jalon J2 sur le serveur de référence (4 vCPU).

Sujet	Mécanisme et valeur de départ	Vérification
Authentification	Jakarta Security 4.0 : HttpAuthenticationMechanism qui valide le JWT ES256 (signature, expiration $\leq$ 15 min, audience) ; domaine de sécurité Elytron avec realm et mappage vers les six rôles (propriétaire, gestionnaire, destinataire, enquêteur, administrateur, auditeur)	Requête sans jeton valide : 401 avant toute lecture du corps
Autorisation	@RolesAllowed sur chaque ressource (rôle), puis contrôle dans le service CDI via le SecurityContext : organisation du principal, organisation de la ressource, destinataire associé, état de la distribution. Refus par défaut ; réponse 403/404 uniforme. Un UUID dans une URL n'est jamais une permission	Tests d'IDOR inter-organisation (CA-02)
Ordre des contrôles	Authentification, puis rôle, puis limites HTTP, puis validation du format et du schéma ; aucun traitement coûteux avant ces quatre étapes	Test : fichier hors quota rejeté sans allocation
Taille des requêtes	Limite Undertow max-post-size alignée sur 50 Mo ; Bean Validation 3.1 sur les DTO ; au plus 1 000 000 lignes, 64 colonnes et 16 Kio par ligne (SR-DIS-02, SR-DIS-03)	CSV hostile : rejet 413/422
Lecture en flux	Le CSV est lu ligne à ligne ; validation et profilage à l'import (passe 1), marquage en flux à partir du stockage chiffré (passe 2). Lots de 500 tuples. Aucun jeu complet n'est chargé dans une collection Java. La détection des doublons de pk garde des empreintes de 128 bits ($\approx$ 16 Mo pour 10^6 lignes)	Mesure du pic de heap par volume (SLI erreur_heap)
Budget de heap	Heap $\geq$ jobs concurrents $\times$ (lot $\times$ colonnes éligibles $\times$ taille d'un BigDecimal + structure de doublons) + marge. Valeur de départ : -Xms = -Xmx = 2 Gio. GC : G1 (défaut) comparé à ZGC générationnel sur la latence p95 ; journaux -Xlog :gc* conservés comme preuve	Stress test ; 0 OutOfMemoryError (voir le document SRE)
Concurrence	Jakarta Concurrency 3.1 : ManagedExecutorService à pool et file bornés (valeur de départ : 4 jobs concurrents pour 4 vCPU), timeout 60 s, annulation par try-with-resources (flux fermés, temporaires supprimés). Débordement : 429. Threads de plateforme pour le calcul (CPU-bound)	Test : deux imports simultanés + dépassement de file
Secrets en mémoire	Clés lues depuis le credential store Elytron, utilisées par le seul composant de marquage, tableaux d'octets effacés après usage. Aucun heap dump automatique contenant du clair en production ; en test, dump vers un répertoire privé chiffré	Revue de code ; recherche de secrets en CI (SR-DEP-03)
Journaux et erreurs	Aucune valeur de tuple ni clé dans les journaux : seulement identifiant de traitement, compteurs et codes. Erreurs RFC 9457 via ExceptionMapper (SR-ERR-01)	Inspection des journaux après les campagnes S1 à S3

9.5 Frontières de confiance : où le middleware intercepte, marque et chiffre

Le marquage est appliqué par le moteur après la frontière F2 (tuples validés) et avant la frontière F3 (écriture chiffrée) : c'est l'unique endroit où le clair des tuples existe, en mémoire contrôlée.

Frontière	Franchissement	Contrôles appliqués côté serveur	Exigences
F1	Navigateur $\rightarrow$ API (HTTPS TLS 1.3)	Le client PWA n'est pas fiable : il affiche les commandes mais ne décide jamais des permissions. Authentification, rôle, organisation et objet sont vérifiés côté serveur, même si l'interface masque un bouton	SR-AUZ-01, SR-AUZ-02
F2	API $\rightarrow$ moteur	Seuls des tuples canonisés et validés, accompagnés d'un SecurityContext autorisé, entrent dans le moteur. L'organisation et le rôle sont déduits du principal authentifié, jamais fournis par le client	SR-INT-08, SR-INT-09

Frontière	Franchissement	Contrôles appliqués côté serveur	Exigences
F3	Moteur → stockage	Le moteur travaille sur le clair par lots. La copie publiée est chiffrée au repos en AES-256-GCM avec une clé gérée hors des fichiers et des journaux. La sortie reste en zone temporaire privée jusqu'à validation du marquage, de l'intégrité et de la transaction de distribution (PENDING → VALIDATED)	SR-CON-01, SR-CON-02
F4	Service → credential store	Seul le composant de marquage lit les clés ; l'administrateur technique n'en voit pas la valeur. Rotation et versionnement (BF-ADM-04) ; procédures d'échec documentées	SR-CON-03, SR-AUZ-06

Limite de confiance. Un serveur de traitement compromis peut accéder aux données en clair pendant le marquage. TupleTrace ne prétend pas offrir un chiffrement de bout en bout ; il limite l'exposition (lots, mémoire bornée, clés hors base, séparation des rôles).

10. Démarche de sécurité

La sécurité suit l'agenda du cours (SQUARE complété par des cas d'abus). Toutes les exigences sont spécifiées dès la séance 2 (Shift-Left), puis le code les rejoint chapitre après chapitre.

10.1 Actifs et besoins C-I-D

Cotation : 1 = faible, 2 = moyen, 3 = élevé.

ID	Actif	C	I	D	Propriété dominante
A1	Jeux de données originaux (non marqués)	3	3	2	Confidentialité
A2	Copies marquées distribuées	2	3	2	Intégrité
A3	Clé maître et sous-clés de marquage	3	3	2	Confidentialité
A4	Clés de signature (Ed25519)	3	3	1	Intégrité
A5	Registre de distribution	2	3	2	Intégrité
A6	Rapports d'investigation	2	3	1	Intégrité
A7	Identités et droits des destinataires	3	2	1	Confidentialité
A8	Journal d'audit	1	3	2	Intégrité
A9	Moteur de traitement (file bornée)	1	2	3	Disponibilité

10.2 Profils d'attaquants

ID	Profil	Capacité et motivation
P1	Destinataire indélicat	Possède une copie légitime ; veut la redistribuer, ou en exfiltrer des lignes, sans être identifié (y compris en nettoyant l'empreinte)
P2	Destinataires colludants	Plusieurs copies ; comparent pour localiser les marques
P3	Utilisateur curieux	Compte valide ; tente d'accéder aux ressources d'une autre organisation
P4	Faussaire de données	Modifie, supprime les marques ou forge une empreinte pour accuser un tiers
P5	Initié malveillant	Administrateur, gestionnaire, enquêteur, auditeur ou développeur ; accès légitime mais partiel aux systèmes
P6	Attaquant externe	Sans compte ; déni de service, fichier piégé, injection

10.3 Cas d'abus

Les cas CA-01 à CA-12 sont inchangés. Les cas CA-13 à CA-18 couvrent les attaques sur la structure des tuples et la menace interne (§ 2.3, 10.7, 10.8).

ID	Scénario	Profil	Parade principale	Test attendu
CA-01	Redistribution d'une copie reçue	P1	Empreinte unique, registre signé (BF-FP-06)	La copie est identifiée sur extrait ≥ 20 %
CA-02	IDOR : téléchargement d'une copie d'autrui par son identifiant	P3	SR-AUZ-02	HTTP 403 / 404 uniforme
CA-03	Collusion : comparaison de copies	P2	Limite assumée ; ≤ 30 destinataires ; filigrane commun préservé	Filigrane toujours détecté après fusion
CA-04	Atténuation des marques (bruit, arrondi, sous-échantillonnage)	P4	Marquage à pas δ ; verdict « Indéterminé »	Aucune attribution forcée
CA-05	Injection de formules CSV (=cmd|...)	P6	SR-INT-03	Champs textuels sécurisés à l'export ; valeurs numériques négatives préservées
CA-06	Fichier piégé, volumineux ou dégénéré	P6	SR-DIS-02	Rejet avant traitement, timeout 60 s
CA-07	Falsification du registre de distribution	P5	SR-INT-05 (signature + chaînage)	Altération détectée par l'audit
CA-08	Vol de la clé maître	P5, P6	SR-CON-03 (credential store, rotation)	Aucune clé dans le dépôt, la base ou les journaux
CA-09	Falsification d'un rapport d'investigation	P4, P5	SR-NRP-02	Signature invalide détectée
CA-10	Auto-validation : le gestionnaire valide sa propre distribution	P5	SR-AUZ-03	Refus ; événement journalisé
CA-11	Téléchargement après révocation ou rejeu d'un lien	P1	SR-AUZ-05, SR-AUT-06	Lien invalide après usage ou expiration
CA-12	Fausse attribution : forger une empreinte ou présenter un extrait non marqué	P4	SR-INT-07 (clés secrètes), Bonferroni	0 fausse attribution sur 1 000 extraits non marqués
CA-13	Permutation des colonnes ou des lignes, renommage d'en-têtes, pour désynchroniser la lecture des marques	P1, P4	Identité sémantique (id_jeu, version_schéma, pk, attribute_id), SR-INT-09	Même décision avant/après permutation ; renommage non reconnu : rejet ou « Indéterminé »
CA-14	Collision d'identité : doublons de pk, en-têtes dupliqués, entrées sérialisées ambiguës (12|34 / 1|234)	P4, P6	SR-INT-08 ; sérialisation à champs de longueur explicite	Import refusé, aucune distribution ; investigation « Indéterminé »
CA-15	Enquêteur corrompu : verdict ou p-valeur arrangés	P5	Recalcul serveur (SR-INT-10), rapport signé, Bonferroni	Valeurs fournies par le client ignorées ; rapport modifié : signature invalide
CA-16	Destinataire légitime qui nettoie l'empreinte avant de divulguer des lignes	P1	Identité sémantique, pas δ, multi-colonnes, quotas et alertes	Courbes de robustesse publiées ; aucune attribution forcée hors domaine
CA-17	Gestionnaire et propriétaire complices : contournement de la double validation ou réattribution d'une copie	P5	SR-AUZ-03, SR-INT-05, SR-LOG-02	Modification d'association refusée et journalisée ; registre inchangé
CA-18	Administrateur ou auditeur : lecture d'un jeu ou d'une clé, altération du journal	P5	SR-AUZ-06, SR-LOG-01	403 ; écriture refusée ; chaîne vérifiée

10.4 Analyse STRIDE

Menace	Instance dans TupleTrace	Parade
Spoofing	Usurpation d'un destinataire ou d'un enquêteur	Argon2id, MFA, JWT ES256 à durée courte
Tampering	Modification du registre, des rapports ou de l'audit ; altération de l'ordre, du nom ou de la clé des tuples	Signatures, chaînage, journal en ajout seul ; identité sémantique des cellules et rejet des collisions
Repudiation	Un acteur nie avoir distribué ou téléchargé	Journal signé, horodatage, identifiant de copie
Information disclosure	Fuite d'un original, d'une clé ou d'une association copie/destinataire	Chiffrement AES-GCM, credential store, RBAC, messages d'erreur neutres
Denial of service	Gros fichiers, rafales d'investigations, saturation de la heap	Limites de taille, quotas, file bornée, lecture en flux par lots, limitation de débit
Elevation of privilege	Administrateur lisant les données, auto-validation, enquêteur ou gestionnaire corrompu	Séparation des rôles, double validation, recalcul serveur, refus par défaut

10.5 Arbres d'attaque

Arbre 1 — Objectif : divulguer un jeu sans être identifié

1. Supprimer ou masquer la marque

— 1.1 Bruit d'amplitude $\geq \delta/2$ sur tout l'extrait (parade : perte d'utilité, verdict « Indéterminé » ; ENF-05)

— 1.2 Collusion de ≥ 2 copies (limite assumée, CA-03)

— 1.3 Sous-échantillonnage extrême (parade : seuil de lignes minimal)

— 1.4 Nettoyage par le destinataire : suppression des colonnes marquées, arrondi $\geq \delta$ (parade : marquage multi-colonnes, robustesse mesurée, CA-16)

— 1.5 Altération de la structure : permutation, renommage, doublons de pk (parade : identité sémantique, rejet des collisions, CA-13, CA-14)

2. Obtenir une copie sans nom

— 2.1 IDOR sur /api/copies (parade : SR-AUZ-02)

— 2.2 Compromission du compte d'un destinataire (parade : Argon2id, MFA, quotas)

— 2.3 Vol ou rejeu d'un lien temporaire (parade : SR-AUZ-05)

3. Corrompre le registre

— 3.1 Injection SQL (parade : requêtes paramétrées, Jakarta Data)

— 3.2 Initié avec accès base (parade : signature et chaînage, SR-INT-05)

— 3.3 Gestionnaire qui réattribue une copie à un autre destinataire (parade : association immuable après validation, CA-17)

Arbre 2 — Objectif : obtenir l'original non marqué ou la clé maître

— 1. Lecture directe du stockage ou des sauvegardes (parade : chiffrement AES-GCM, sauvegardes chiffrées)

— 2. Abus de privilèges de l'administrateur (parade : aucun accès aux jeux ni aux clés, SR-AUZ-06)

— 3. Fuite via journaux ou messages d'erreur (parade : ExceptionMapper RFC 9457, journaux sans secret)

— 4. Clé commitée dans le dépôt (parade : recherche de secrets en CI, SR-DEP-03)

10.6 Familles d'exigences et exemples

Le référentiel complet (≥ 50 exigences, 11 familles) est tenu dans le recueil et dans docs/exigences.csv ; voici les exigences structurantes. Les exigences SR-INT-08, SR-INT-09, SR-INT-10 et SR-DIS-03 sont introduites par la version 2.0 et à reporter dans le recueil et dans le référentiel CSV.

ID	Exigence	Prio
SR-CON-01	Les fichiers originaux et copies sont chiffrés au repos (AES-256-GCM)	P1
SR-CON-02	L'original non marqué n'est jamais téléchargeable ni exposé par l'API	P1
SR-CON-03	Les clés de marquage et de signature sont dans le credential store, jamais en base ni dans le dépôt	P1
SR-CON-04	Sans la clé, la présence et l'emplacement du sceau ne sont pas déterminables (positions HMAC)	P1
SR-INT-01	Chaque jeu est lié à un SHA-256 conservé à l'import	P1
SR-INT-02	Aucune modification n'excède la tolérance de la colonne ; sinon refus	P1
SR-INT-03	Les champs textuels pouvant être interprétés comme des formules par un tableur sont échappés lors d'un export destiné à un tableur ; les valeurs numériques signées, comme -3,5, restent valides et ne sont pas altérées à l'import. Les valeurs importées ne sont jamais modifiées silencieusement.	P1
SR-INT-05	Le registre de distribution est signé et chaîné	P1
SR-INT-07	Un verdict d'attribution exige un test statistique corrigé (Bonferroni) ; sinon « Indéterminé »	P1
SR-INT-08	Un import est refusé en cas de pk dupliquée ou nulle, d'en-tête dupliqué ou de renommage non reconnu ; aucune correspondance n'est inventée	P1
SR-INT-09	L'identité d'une cellule est (id_jeu, version_schéma, pk, attribute_id), sérialisée à champs de longueur explicite ; sélection et bits attendus sont indépendants de l'ordre des lignes et des colonnes	P1
SR-INT-10	n, k, p-valeur et seuil corrigé sont recalculés côté serveur à partir de l'extrait stocké ; le client ne les fournit jamais	P1
SR-NRP-01	Chaque distribution et chaque téléchargement sont journalisés avec l'identité de l'acteur	P1
SR-NRP-02	Les rapports d'investigation sont signés (Ed25519)	P1
SR-AUT-01	Mots de passe hachés en Argon2id ; longueur ≥ 12	P1
SR-AUT-02	MFA obligatoire pour propriétaire, administrateur et auditeur	P1
SR-AUT-04	JWT ES256, durée ≤ 15 min, refresh avec rotation	P1
SR-AUT-06	Un lien de téléchargement est à usage limité et expire sous 24 h	P1
SR-AUZ-01	Refus par défaut ; matrice des droits appliquée côté serveur	P1
SR-AUZ-02	Tout accès à un jeu, une copie ou un rapport vérifie l'organisation et la ressource (pas d'IDOR)	P1
SR-AUZ-03	Une distribution n'est générée qu'après validation par un propriétaire différent du préparateur	P1
SR-AUZ-05	Un accès révoqué interdit tout nouveau téléchargement immédiatement	P1
SR-AUZ-06	L'administrateur technique n'a aucun accès aux jeux, copies ni clés	P1
SR-PRV-01	Les associations copie/destinataire ne sont visibles que par les rôles habilités	P1
SR-PRV-02	Seules des données synthétiques ou publiques sont utilisées en test	P1

ID	Exigence	Prio
SR-LOG-01	Journal d'audit chaîné, en ajout seul ; accès en lecture réservé à l'auditeur	P1
SR-LOG-02	Alerte sur volume anormal de téléchargements ou d'investigations	P2
SR-ERR-01	Erreurs au format RFC 9457, sans trace interne ni secret	P1
SR-DIS-01	Traitements dans une file bornée avec timeout de 60 s	P1
SR-DIS-02	Fichiers limités à 50 Mo et 1 000 000 lignes ; schéma validé avant traitement	P1
SR-DIS-03	Lecture du CSV et des résultats JDBC en flux par lots bornés ; nombre de colonnes, longueur de ligne et jobs concurrents bornés ; aucun jeu complet chargé en mémoire	P1
SR-TST-04	Chaque cas d'abus est couvert par un test démontrant l'échec de l'attaque	P1
SR-DEP-03	Recherche de secrets en CI ; conteneurs non root ; en-têtes de sécurité	P1

10.7 Menaces de transformation propres aux structures relationnelles

L'enjeu de sécurité porte sur la structure du tuple : un adversaire n'a pas besoin de casser la cryptographie s'il peut faire dévier l'identité des cellules lues. Chaque transformation possible reçoit une décision de conception explicite.

Transformation possible	Impact sur la preuve	Décision de conception
Réordonner les lignes	Aucun si la pk est conservée	Identification logique des lignes (CA-13)
Permuter les colonnes	Risque de désynchronisation des bits	Correspondance par attribute_id ; colonnes éligibles ordonnées canoniquement
Dupliquer des clés	Collision d'identité	Refuser et journaliser (CA-14)
Supprimer certaines lignes	Réduction des échantillons	Seuil de lignes minimal, statut « Indéterminé »
Supprimer la clé stable	Identité des tuples perdue	Hors garantie : « Indéterminé » (§ 6.6)
Arrondir les valeurs	Peut effacer les marques	Pas δ ; robustesse mesurée, aucune promesse absolue
Renommer un attribut	Identité ambiguë	Mapping versionné explicite ou refus
Joindre ou agréger	Détruit le contrat initial	Hors périmètre du MVP

10.8 Menace interne : cas d'abus de l'attaquant légitime

Dans une application de traçabilité, le danger principal vient de l'attaquant **interne légitime** : un destinataire, un gestionnaire, un enquêteur ou un auditeur disposant d'un accès autorisé, qui cherche à exfiltrer des lignes en nettoyant ou en contournant l'empreinte, ou à fausser la preuve. Une défense limitée à l'écran de connexion est donc inopérante. Quatre principes de conception s'appliquent :

— **séparation des rôles** : préparer, valider, enquêter, administrer et auditer relèvent de rôles distincts ; l'administrateur technique n'hérite d'aucun droit d'enquête ni d'accès aux jeux ;

— **preuve recalculée côté serveur** : aucun résultat statistique n'est accepté du client ;

— **intégrité vérifiable par un autre rôle** : registre signé et chaîné, journal en ajout seul, contrôlé par l'auditeur ;

— **aucune promesse excessive** : TupleTrace n'empêche pas la divulgation par une personne ayant obtenu le clair et ne prouve pas l'identité de l'auteur de la fuite ; il vise la reconnaissance de la copie d'origine dans des conditions documentées.

CA-15 — Enquêteur corrompu qui publie un verdict arrangé

Élément	Description
Acteur	Enquêteur autorisé (P5)
Objectif	Accuser un destinataire ou innocenter un complice
Étapes	1. Soumet un extrait fabriqué à partir de lignes de la copie d'un tiers. 2. Tente d'imposer n, k, la p-valeur ou le seuil dans la requête. 3. Tente de modifier un rapport exporté.
Contre-mesures codables	Le serveur ne reçoit que l'extrait et recalcule n, k, p-valeur et seuil α/N (SR-INT-10, SR-INT-07). Rapport signé Ed25519 (SR-NRP-02). Chaque investigation est journalisée avec le hash de l'extrait (SR-NRP-01). Un enquêteur n'accède qu'à ses investigations
Limite	Un extrait réellement issu de la copie d'un tiers révèle légitimement la marque de ce tiers : le rapport reste un indice technique, jamais une preuve de responsabilité
Test	Requête avec p-valeur forgée : valeur ignorée. Rapport altéré : signature invalide. Extrait non marqué : « Aucune marque détectée » ou « Indéterminé »

CA-16 — Destinataire légitime devenu adversaire : nettoyage de l'empreinte

Élément	Description
Acteur	Destinataire possédant déjà une copie autorisée (P1)
Objectif	Exfiltrer ou republier des lignes sans être identifié
Étapes	1. Télécharge sa copie (accès légitime). 2. Supprime des colonnes marquées ou des lignes, arrondit à une précision $\geq \delta$, ajoute du bruit. 3. Permute les colonnes, trie les lignes, renomme les en-têtes.
Contre-mesures codables	Identité sémantique : permutation et tri sans effet (SR-INT-09). Renommage non reconnu : refus ou « Indéterminé ». Marquage réparti sur plusieurs colonnes éligibles : supprimer une colonne n'efface qu'une part de la marque. Lien de téléchargement à usage limité et quotas ; alerte sur volume anormal (SR-LOG-02)
Limite	Un arrondi plus grossier que δ ou un bruit $\geq \delta/2$ détruit la marque au prix d'une perte d'utilité des données ; le verdict devient « Indéterminé », jamais une attribution forcée
Test	Simulateur : suppression de lignes et de colonnes, arrondi, bruit, permutation (§ 11.2) ; courbes de détection et d'indétermination publiées

CA-17 — Gestionnaire et propriétaire complices

Élément	Description
Acteur	Gestionnaire de distribution et propriétaire (P5)
Objectif	Contourner la double validation ou réattribuer une copie à un autre destinataire pour brouiller l'attribution
Étapes	1. Tente de valider sa propre distribution, ou de modifier le destinataire d'une copie déjà validée. 2. Tente de modifier une entrée du registre.
Contre-mesures codables	Validateur $\neq$ préparateur vérifié côté serveur (SR-AUZ-03). Association copie/destinataire immuable après validation : tout changement passe par une nouvelle distribution. Registre signé et chaîné, qui enregistre les deux identités (SR-INT-05). MFA du propriétaire. Alerte sur volumes ou couples inhabituels (SR-LOG-02)
Limite	Deux personnes réellement complices ne sont pas empêchées de valider ensemble : la parade est la traçabilité et la détection a posteriori par l'auditeur

Élément	Description
Test	Auto-validation et mutation de l'association : refus, événement journalisé, registre inchangé

CA-18 — Administrateur technique, auditeur ou développeur

Élément	Description
Acteur	Administrateur technique, auditeur ou développeur (P5)
Objectif	Lire des données métier ou des clés secrètes, ou effacer les traces d'une action
Étapes	1. L'administrateur interroge un jeu, une copie ou une clé. 2. L'auditeur ou l'administrateur tente de modifier ou de supprimer un journal. 3. Le développeur laisse une clé dans le dépôt.
Contre-mesures codables	L'administrateur n'a aucun accès aux jeux, copies ni clés (SR-AUZ-06) et n'hérite pas des droits d'enquête. Journal en ajout seul, en lecture pour l'auditeur uniquement, privilèges base d'écriture retirés, chaînage SHA-256 signé périodiquement (SR-LOG-01). Recherche de secrets en CI (SR-DEP-03)
Test	Accès d'un administrateur à un jeu : 403. Écriture ou suppression dans le journal : refusée ; une altération manuelle de la base est détectée par la vérification de chaîne

11. Tests et évaluation expérimentale

11.1 Banc d'essai

Le banc comprend 30 jeux synthétiques (lois uniforme, gaussienne, entiers bornés) de 1 000, 10 000 et 100 000 lignes, plus 2 jeux publics adaptés. Il est généré par script (graine fixe, ENF-08).

11.2 Simulateur de transformations

Transformation	Paramètres de test
Suppression de lignes / échantillonnage	10 %, 30 %, 50 %, 80 % supprimées
Suppression de colonnes	1 colonne marquée supprimée
Arrondi	précision $\geq \delta$ puis 2δ
Bruit uniforme	d'amplitude $\delta/8$, $\delta/4$, $\delta/2$
Réordonnancement	permutation aléatoire des lignes et colonnes
Combinaisons	suppression 50 % + bruit $\delta/4$

11.3 Indicateurs

Mesure	Ce qu'elle évalue	Cible
Taux de détection	Part des extraits marqués reconnus	$\geq$ 95 % dans le domaine ENF-05
Faux positifs	Part des extraits non marqués reconnus à tort	0 sur 1 000 ; p $< 10^{-6}$ par test
Précision d'attribution	Copies correctement reliées	$\geq$ 95 % (ENF-07)
Taux d'erreur d'extraction (BER)	Bits de filigrane mal extraits sur copie complète, puis sous transformation	0 % sans attaque ; $\leq$ 1 % sous bruit $\leq \delta/4$ (voir le document SRE)
Distorsion	Écarts moyen et maximal, effet sur moyenne et variance	ENF-04
Temps de traitement	Durée du marquage et de la détection selon la taille	ENF-01, 02

Mesure	Ce qu'elle évalue	Cible
Consommation mémoire	Pic de heap par volume de lignes, erreurs OutOfMemoryError	0 erreur ; plafond de heap fixé à J2 (§ 9.4)

11.4 Critères de recette

Le MVP est accepté si une démonstration complète fonctionne sur des données de test, si les tolérances sont respectées, si deux destinataires reçoivent des copies distinctes, si une copie connue est reconnue dans un cas expérimental documenté, et si une copie inconnue n'est pas attribuée arbitrairement.

11.5 Traçabilité des campagnes complémentaires

Les campagnes complémentaires portent sur la structure des tuples, les abus, la mémoire et l'intégrité des distributions. Elles couvrent notamment : permutation des lignes et colonnes, doublons et valeurs nulles de pk, renommage d'attributs, suppression de lignes ou de colonnes, arrondi, bruit, collusion, tentatives d'IDOR, dépassement de quotas, interruption avant validation, falsification des paramètres statistiques et altération du journal.

Le protocole détaillé, les jeux d'essai, les paramètres de chaque campagne, les résultats attendus et les preuves à archiver sont définis dans le document SRE et dans les scripts de test du dépôt. Chaque exécution conserve la version du moteur, le jeu synthétique et sa graine, la configuration, la machine, la JVM, la durée et le résultat. Les échecs sont documentés au même titre que les réussites.

12. Risques

12.1 Risques projet

Risque	Impact	Parade
Marquage non robuste après transformation	OM-3 partiellement atteint	Prototype dès J2 sur le banc ; pas δ ajustable ; redondance et code correcteur réglables ; verdict « Indéterminé »
Données peu tolérantes aux écarts	Capacité insuffisante	Choix des colonnes dès le début ; γ réglable ; refus motivé
Capacité insuffisante pour trois couches	Sceau illisible	Contrôle de capacité préalable, essai de récupération du sceau et désactivation documentée si ces contrôles échouent
Petits extraits	Verdict faible	Seuils de lignes minimaux ; statut « Indéterminé »
Complexité technique (Jakarta EE 11, WildFly 42, Java 25)	Retard	Squelette déployé dès J1
Saturation de la heap Java sur gros volumes	Traitement interrompu, déni de service	Lecture en flux, lots et file bornés, tests de charge (§ 9.4, SLI erreur_heap)
Identités de tuples ambiguës (doublons, renommages, permutations)	Marque illisible ou fausse attribution	Identité sémantique, rejet des collisions, statut « Indéterminé » (§ 2.3)
Initié corrompu (enquêteur, gestionnaire, auditeur)	Preuve faussée	Séparation des rôles, recalcul serveur, journal chaîné (§ 10.8)

Risque	Impact	Parade
Charge de travail (exigences de sécurité communes à tous les groupes)	Retard	Priorisation : P1 d'abord ; besoins « Could » abandonnables
Évolution des exigences	Incohérences documentaires	Référentiel unique (CSV) régénéré à chaque évolution

12.2 Conclusion et références

TupleTrace place le watermarking, la stéganographie et le fingerprinting de données tabulaires au centre d'une plateforme web sécurisée. Le projet reste réalisable sous forme d'un MVP mesurable ; la robustesse est mesurée au prototype, non supposée.